

Painless Authentication

with Access Tokens



Mathieu Santostefano

👤 Web developer at <code>joliCode</code>

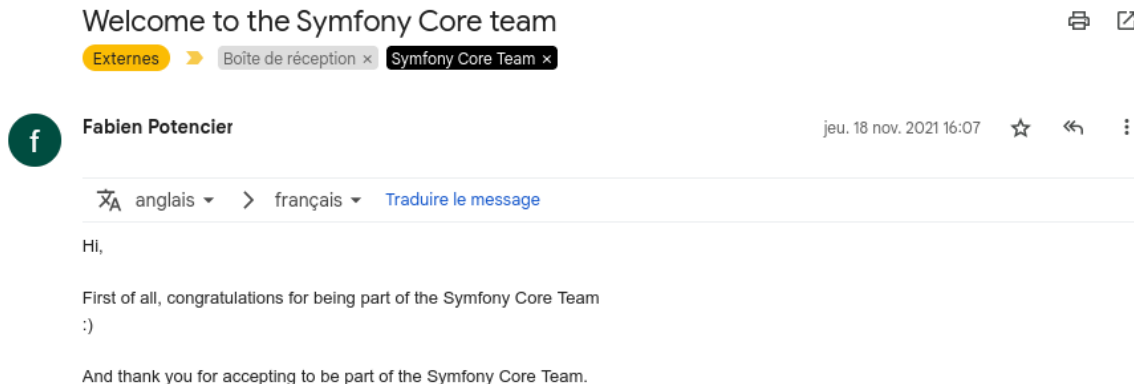
📄 Symfony Core Team Member

🐦 Twitter [@welcomattic](https://twitter.com/welcomattic)

🐙 GitHub [@welcomattic](https://github.com/welcomattic)



On nov. 18 2021, I received an email to join the Core Team



On the menu



On the menu

1. Access token, what is it?





On the menu

1. Access token, **what is it?**
2. Implementation with **Symfony 6.1**





On the menu

1. Access token, **what is it?**
2. Implementation with **Symfony 6.1**
3. Time travel





On the menu

1. Access token, **what is it?**
2. Implementation with **Symfony 6.1**
3. Time travel
4. Implementation with **Symfony 6.2**





On the menu

1. Access token, **what is it?**
2. Implementation with **Symfony 6.1**
3. Time travel
4. Implementation with **Symfony 6.2**
5. Code examples





On the menu

1. Access token, **what is it?**
2. Implementation with **Symfony 6.1**
3. Time travel
4. Implementation with **Symfony 6.2**
5. Code examples
6. In the future?





**Who has Access Token
authentication in their app?**

 **Who is working with the
new *Symfony Security*?**

Who is working with the new *Symfony Security*?

Thank you for it, Wouter 🙏

✨ The New Security System

- Removed everything but Guards
- Moved to an event-based system
- Authenticator based: instantiate a Passport with Badges

Your job is to use Authenticator or implement your own

✨ The New Security System

Event-based system

- You can interact on different levels
 - `CheckPassportEvent`
 - `AuthenticationTokenCreatedEvent`
 - `AuthenticationSuccessEvent`
 - `LoginSuccessEvent`
 - `LoginFailureEvent`
 - `LogoutEvent`
 - `TokenDeauthenticatedEvent`
 - `SwitchUserEvent`

✨ The New Security System

As before, you can still handle what happens in case of authentication success or failure



Like many things since the last years in Symfony, it improves the **DX**



What is an Access Token?



What is an Access Token?

- `i-am-an-4cc3ss-t0k3n` could be an Access Token



What is an Access Token?

- `i-am-an-4cc3ss-t0k3n` could be an Access Token
- `mF_9.B5f-4.1JqM` could be an Access Token



What is an Access Token?

- `i-am-an-4cc3ss-t0k3n` could be an Access Token
- `mF_9.B5f-4.1JqM` could be an Access Token
- `eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4...`
could be an Access Token



What is an Access Token?

- `i-am-an-4cc3ss-t0k3n` could be an Access Token
- `mF_9.B5f-4.1JqM` could be an Access Token
- `eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4...`
could be an Access Token
- 🍌 could be an Access Token



What is an Access Token?

- `i-am-an-4cc3ss-t0k3n` could be an Access Token
- `mF_9.B5f-4.1JqM` could be an Access Token
- `eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4...`
could be an Access Token
- 🍌 could be an Access Token



An Access Token is represented by a string.



Use cases

Authentication with **Access Token** is useful in some contexts, like

- Stateless user login
- **API Gateway** in front of private APIs
- Application that access to personal data provided by a third party
- **Micro-services** between them
- Client applications of a **SaaS API**
- ...



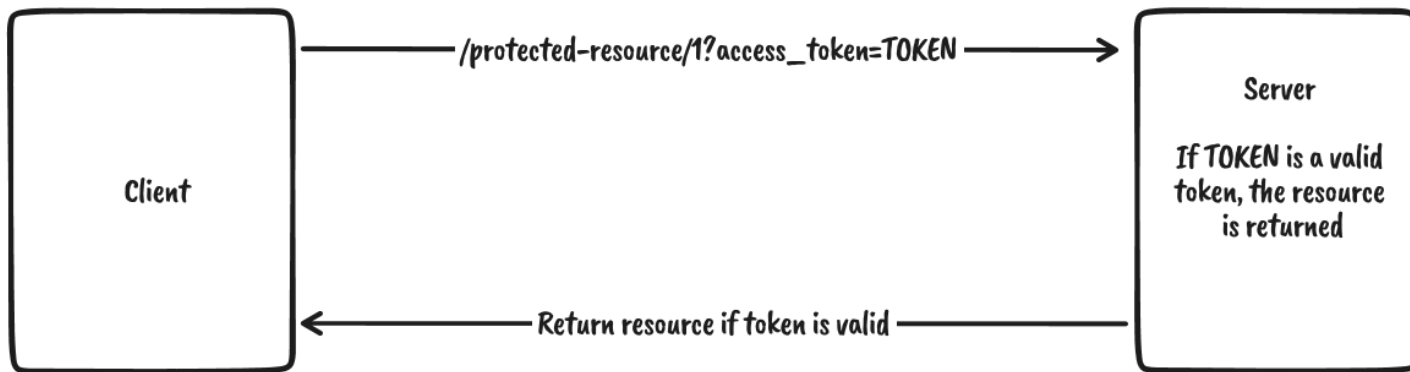
Ok, so?

- Must be sent in a **HTTP request** to fetch a protected resource
- The application expects to find a token,  **validate**  it and decide to allow access or not



Ok, so?

- Must be sent in a **HTTP request** to fetch a protected resource
- The application expects to find a token, 🖐️ **validate** 🖐️ it and decide to allow access or not





Token issuer

**Let's assume our tokens come from an external authentication server,
the user identity has been verified by this server**



Validate the token?

The validation process is up to you

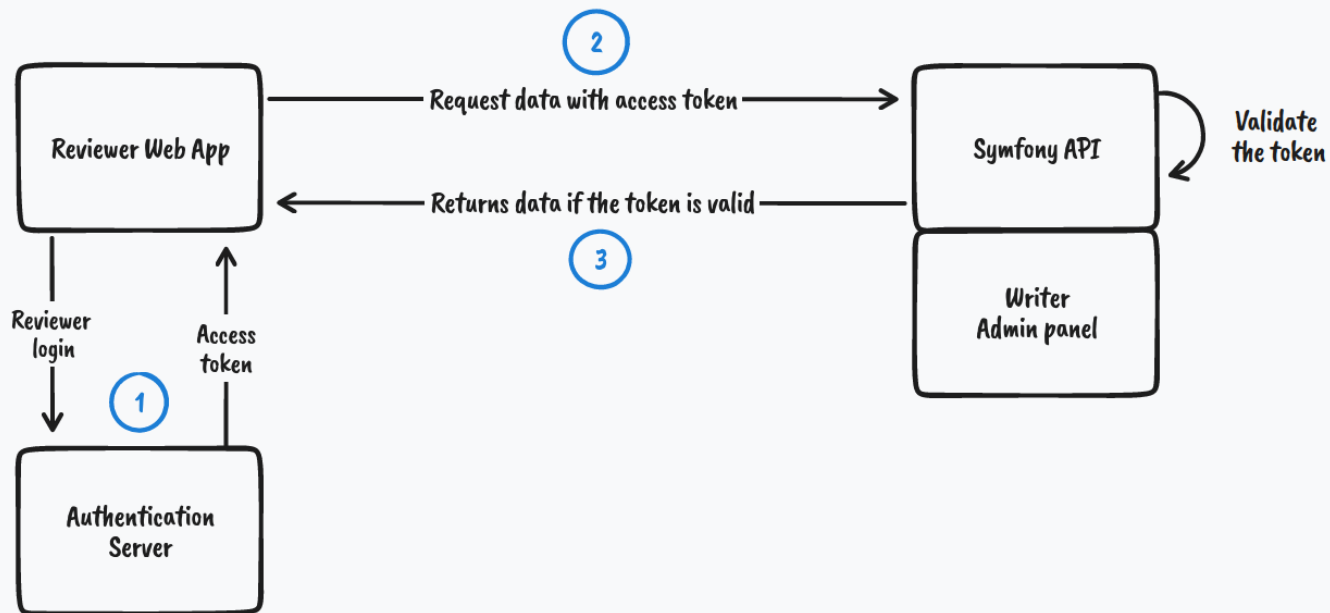
- Check if the string is **present** in a database
- **Compute a hash** and compare it to the expected one
- **Decode the token** (base64, ...) and make **assertions** on decoded values
- Ensure the **expiration date** is not passed if needed
- Check if the token has been **revoked** or not
- Call an **OpenID Connect** server to validate the token
- ...

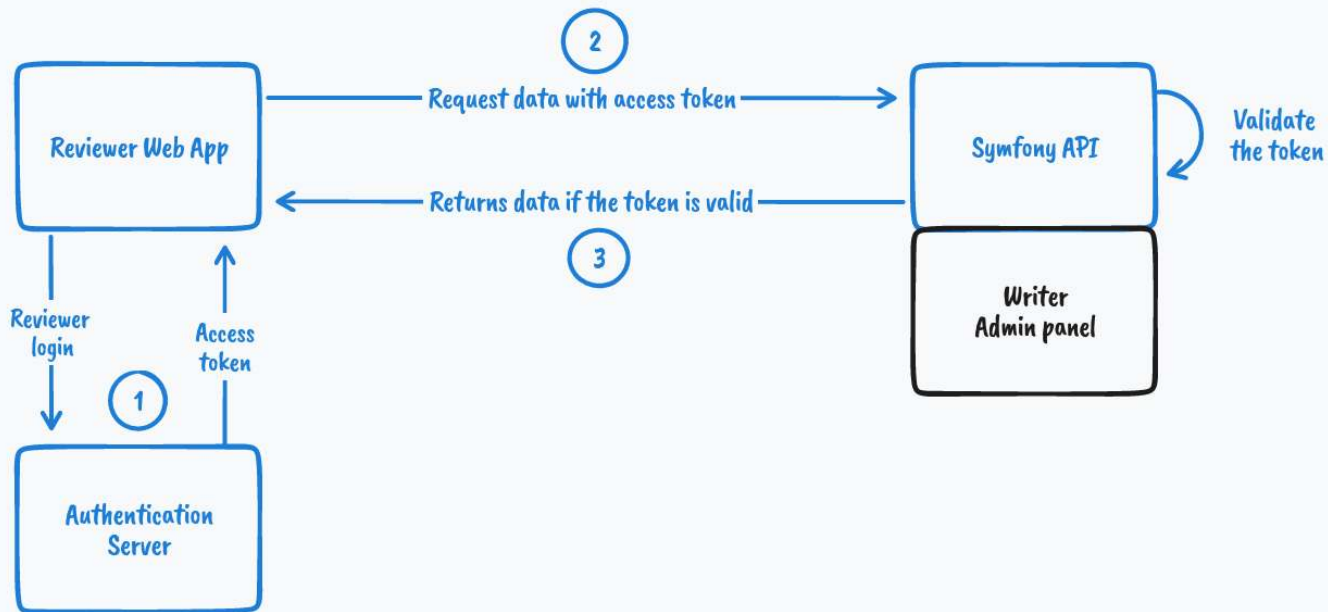
How to set up an Access Token auth with Symfony?



Marvel Scenarios Manager, a web app for writers and reviewers

- Each user (Writers and Reviewers) has an API key
- Admin for Writers
 - Form login authentication
 - Writers can create Scenarios
- Web app for Reviewers
 - Call the private API using API Key obtained after Reviewer login
- Admins can revoke API key at any time







With Symfony <= 6.1

Create a custom Authenticator

1. Extract **token**
2. Decode **token** if needed (JWT, SAML, ...)
3. Check **token** validity
4. Retrieve user identifier from the **token**
5. Then load User object
6. Handle authentication failure cases



Have you heard about RFC 6750?

- Token transportation
 - In **request header**? → `Authorization` header
 - In **query string**? → parameter `access_token`
 - In **request body**? → parameter `access_token`



Have you heard about RFC 6750?

- Token transportation
 - In **request header**? → `Authorization` header
 - In **query string**? → parameter `access_token`
 - In **request body**? → parameter `access_token`
- `WWW-Authenticate` **response header** in case of failure



Have you heard about RFC 6750?

- Token transportation
 - In **request header**? → `Authorization` header
 - In **query string**? → parameter `access_token`
 - In **request body**? → parameter `access_token`
- `WWW-Authenticate` **response header** in case of failure
- **HTTPS** protocol mandatory

Your responsibility

Symfony's responsibility,
but customizable

Access Token Authentication Process

≤ 6.1





Some code

```
1  /** Simplified version */
2  private function extractToken(Request $req): ?string
3  {
4      return match (true) {
5          // Header
6          $req->headers->has('Authorization') => str_replace('Bearer ', '', $req->headers->get('Authorization')),
7
8          // Query string
9          $req->query->has('access_token') => $req->query->get('access_token'),
10
11         // Request body
12         $req->request->has('access_token') => $req->request->get('access_token'),
13
14         default => null,
15     };
16 }
```



Some code

```
1  public function authenticate(Request $req): Passport
2  {
3      if (null === $apiKey = $this->extractToken($req)) {
4          throw new AuthenticationException('No API Key provided');
5      }
6
7      // Here, it could be some logic to validate the token
8
9      return new SelfValidatingPassport(
10         new UserBadge($apiKey,
11             function (string $apiKey) {
12                 return $this->userRepository->findOneByApiKey($apiKey);
13             }
14         )
15     );
16 }
```



Boring code

- We have to repeat this code in all our applications, **boring**
- Our responsibility to respect RFC6750, **boring**
- No body likes boring code
- Boring code is code we rewrite in all projects, no business value
- Poor **D**eveloper **eX**perience, Symfony tends to improve DX

This is definitely improvable





Discussions started long time ago

- April 2019, at EU FOSSA Hackathon

Closed 24 of 35 tasks **[RFC] Symfony Security rework tracking issue #30914**
curry684 opened this issue on Apr 6, 2019 · 42 comments

Authentication

- ☒ User impersonation (including multiple impersonation without having to log out) *not affected by Security changes*
- ☒ Social login (login in the app using Google, Facebook, GitHub, Twitter, etc.) and generic OAuth support (🔴🔴 [WIP][Security] [OAuth2 component](#) #31952 (comment))
- ☒ Login throttling (limit the number of failed login attempts over a period of time)
- ☐ Simultaneous session limiting (e.g. each user can login only from one device at the same time)
- ☒ Two factor (or multi factor) authentication (🟢 [Security] [Native support for 2FA](#) #28868 (comment))



SymfonyCon
DISNEYLAND PARIS
NOV.17-18 2022



Discussions started long time ago

- June 2019, first PR about OAuth2 Component. **✗** Aborted

[WIP][Security] OAuth2 component #31952

❗ Closed symfony:master ← Guikingone:feat/oauth

🗨 Conversation 45 -🔽 Commits 2 📄 Checks 0 📄 Files changed 67

 **Guikingone** (Guillaume Loulier) on Jun 8, 2019 • edited ▾ Contributor 😊 ✎ ⋮

Q	A
Branch?	master
Bug fix?	no
New feature?	yes



Discussions started long time ago

- September 2019, Wouter's 1st PR about redesign of Security

[Security] AuthenticatorManager to make "authenticators" first-class security #33558

Merged by fabpot symfony:master ← wouterj:security/deprecate-providers-listeners on Apr 21, 2020 v5.1.0-BETA1

Conversation 177 Commits 30 Checks 0 Files changed 77

wouterj (Wouter de Jong) on Sep 11, 2019 • edited

Q	A
Branch?	master
Bug fix?	no
New feature?	yes
Deprecations?	no
Tickets	-

Reviewers – review now

- javiereguilluz
- rosier
- nicolas-grekas
- stof
- noniagriconomie
- fabpot
- weaverryan
- chalar



Discussions started long time ago

- April 2020, continuation of Wouter's work on new Security system

[Security] Integrated Guards with the Authenticator system #36570

Merged by fabpot symfony/master ← wouterj:security/new-system-guard on Apr 25, 2020 v6.1.0-BETA1

Conversation (4) Commits (1) Checks (0) Files changed (4)

wouterj (Wouter de Jong) on Apr 24, 2020 • edited

Q	A
Branch?	master
Bug fix?	no
New feature?	yes
Deprecations?	no
Tickets	-

Reviewers - review now
fabpot
chalar

Assignees - assign yourself

Labels
Security Status: Pending

Projects

[Security] Removed anonymous in the new security system #36574

Merged by fabpot symfony/master ← wouterj:security/remove-anonymous on May 3, 2020 v6.1.0-BETA1

Conversation (17) Commits (1) Checks (0) Files changed (14)

wouterj (Wouter de Jong) on Apr 24, 2020 • edited

Q	A
Branch?	master
Bug fix?	no
New feature?	yes
Deprecations?	no
Tickets	-

Reviewers - review now
javierreguluz
weaverryan
simonberger
fabpot

Assignees - assign yourself

Labels
Security



Discussions started long time ago

- March 2022, Vincent Chalamon opens an issue about "Bearer Authenticator"

[Security] Add Bearer Authenticator #45844

Closed 14 comments · Fixed by #46428

vincentchalamon (Vincent) on Mar 25 · edited

Description

I'm implementing an OIDC architecture in an API first project, and wanted to secure my API with an authenticator. I first took a look at bundles like `hwi/oauth-bundle` or `knpuiversity/oauth2-client-bundle`, but they're not adapted to an API as they provide bunch of features not needed in an API, and provides their own JWT generation and storage (e.g.: cookie).

I talked about it with @dunglas who shares the idea to implement a Bearer authenticator directly in the Symfony Security bundle. The idea behind this authenticator would be to retrieve the token from the `Authorization` header (prefixed with `Bearer`), and validate and decode it in a `BearerToken` using `lcobucci/jwt`.

Example

```
# config/packages/security.yaml
security:
    ...
    firewall:
        ...
        main:
            ...
            bearer:
                ...
                signature: '/path/to/signature/key' # Could be a file path, plaintext, or even an url
                algorithm: 'hmac.sha256'
                key: 'customUserId' # Which key from the JWT should be sent to the UserProvider (default: '')
```

Assignees – assign yourself

Labels

Feature Security

Projects

None yet

Milestone

No milestone

Development

Successfully merging a pull request may close this issue.

[Security] Access Token Authenticator
Spomky/symfony

[Security] Implement HttpBearerAuthenticator
vincentchalamon/symfony



Discussions started long time ago

- Finally, on **May 21st, 2022**, Vincent Chalamon & Florent Morselli each open a pull request to implement the Authenticator

[Security] Implement HttpBearerAuthenticator #46429

🔒 Closed symfony/symfony ← vincentchalamon:feat/security/bearer-authenticator

Conversation 2 · Commits 1 · Checks 7 · Files changed 14

vincentchalamon (Vincent) on May 21

Q	A
Branch?	6.2
Bug fix?	no
New feature?	yes
Deprecations?	no
Tickets	Fix #45844
License	MIT

Reviewers - review
wouterj
chalar

Assignees - assign

Labels
Security Status

Projects
None yet

[Security] Access Token Authenticator #46428

🔒 Merged by chalar symfony/symfony ← Spooky:features/access-token-authenticator on Aug 10

Conversation 195 · Commits 1 · Checks 7 · Files changed 38

Spooky (Florent Morselli) on May 21 · edited

Q	A
Branch?	6.2
Bug fix?	yes
New feature?	yes
Deprecations?	no
Tickets	Fix #45844
License	MIT
Doc PH	symfony/symfony-docs#16819

Reviewers - review rose
vincentchalamon
lyricx
stef
94roni
dermbus
dungles
wouterj
chalar

Assignees - assign yourself

Labels
6.2 6.3 6.4 6.5 6.6 6.7 6.8 6.9 7.0 7.1 7.2 7.3 7.4 7.5 7.6 7.7 7.8 7.9 8.0 8.1 8.2 8.3 8.4 8.5 8.6 8.7 8.8 8.9 9.0 9.1 9.2 9.3 9.4 9.5 9.6 9.7 9.8 9.9 10.0 10.1 10.2 10.3 10.4 10.5 10.6 10.7 10.8 10.9 11.0 11.1 11.2 11.3 11.4 11.5 11.6 11.7 11.8 11.9 12.0 12.1 12.2 12.3 12.4 12.5 12.6 12.7 12.8 12.9 13.0 13.1 13.2 13.3 13.4 13.5 13.6 13.7 13.8 13.9 14.0 14.1 14.2 14.3 14.4 14.5 14.6 14.7 14.8 14.9 15.0 15.1 15.2 15.3 15.4 15.5 15.6 15.7 15.8 15.9 16.0 16.1 16.2 16.3 16.4 16.5 16.6 16.7 16.8 16.9 17.0 17.1 17.2 17.3 17.4 17.5 17.6 17.7 17.8 17.9 18.0 18.1 18.2 18.3 18.4 18.5 18.6 18.7 18.8 18.9 19.0 19.1 19.2 19.3 19.4 19.5 19.6 19.7 19.8 19.9 20.0 20.1 20.2 20.3 20.4 20.5 20.6 20.7 20.8 20.9 21.0 21.1 21.2 21.3 21.4 21.5 21.6 21.7 21.8 21.9 22.0 22.1 22.2 22.3 22.4 22.5 22.6 22.7 22.8 22.9 23.0 23.1 23.2 23.3 23.4 23.5 23.6 23.7 23.8 23.9 24.0 24.1 24.2 24.3 24.4 24.5 24.6 24.7 24.8 24.9 25.0 25.1 25.2 25.3 25.4 25.5 25.6 25.7 25.8 25.9 26.0 26.1 26.2 26.3 26.4 26.5 26.6 26.7 26.8 26.9 27.0 27.1 27.2 27.3 27.4 27.5 27.6 27.7 27.8 27.9 28.0 28.1 28.2 28.3 28.4 28.5 28.6 28.7 28.8 28.9 29.0 29.1 29.2 29.3 29.4 29.5 29.6 29.7 29.8 29.9 30.0 30.1 30.2 30.3 30.4 30.5 30.6 30.7 30.8 30.9 31.0 31.1 31.2 31.3 31.4 31.5 31.6 31.7 31.8 31.9 32.0 32.1 32.2 32.3 32.4 32.5 32.6 32.7 32.8 32.9 33.0 33.1 33.2 33.3 33.4 33.5 33.6 33.7 33.8 33.9 34.0 34.1 34.2 34.3 34.4 34.5 34.6 34.7 34.8 34.9 35.0 35.1 35.2 35.3 35.4 35.5 35.6 35.7 35.8 35.9 36.0 36.1 36.2 36.3 36.4 36.5 36.6 36.7 36.8 36.9 37.0 37.1 37.2 37.3 37.4 37.5 37.6 37.7 37.8 37.9 38.0 38.1 38.2 38.3 38.4 38.5 38.6 38.7 38.8 38.9 39.0 39.1 39.2 39.3 39.4 39.5 39.6 39.7 39.8 39.9 40.0 40.1 40.2 40.3 40.4 40.5 40.6 40.7 40.8 40.9 41.0 41.1 41.2 41.3 41.4 41.5 41.6 41.7 41.8 41.9 42.0 42.1 42.2 42.3 42.4 42.5 42.6 42.7 42.8 42.9 43.0 43.1 43.2 43.3 43.4 43.5 43.6 43.7 43.8 43.9 44.0 44.1 44.2 44.3 44.4 44.5 44.6 44.7 44.8 44.9 45.0 45.1 45.2 45.3 45.4 45.5 45.6 45.7 45.8 45.9 46.0 46.1 46.2 46.3 46.4 46.5 46.6 46.7 46.8 46.9 47.0 47.1 47.2 47.3 47.4 47.5 47.6 47.7 47.8 47.9 48.0 48.1 48.2 48.3 48.4 48.5 48.6 48.7 48.8 48.9 49.0 49.1 49.2 49.3 49.4 49.5 49.6 49.7 49.8 49.9 50.0 50.1 50.2 50.3 50.4 50.5 50.6 50.7 50.8 50.9 51.0 51.1 51.2 51.3 51.4 51.5 51.6 51.7 51.8 51.9 52.0 52.1 52.2 52.3 52.4 52.5 52.6 52.7 52.8 52.9 53.0 53.1 53.2 53.3 53.4 53.5 53.6 53.7 53.8 53.9 54.0 54.1 54.2 54.3 54.4 54.5 54.6 54.7 54.8 54.9 55.0 55.1 55.2 55.3 55.4 55.5 55.6 55.7 55.8 55.9 56.0 56.1 56.2 56.3 56.4 56.5 56.6 56.7 56.8 56.9 57.0 57.1 57.2 57.3 57.4 57.5 57.6 57.7 57.8 57.9 58.0 58.1 58.2 58.3 58.4 58.5 58.6 58.7 58.8 58.9 59.0 59.1 59.2 59.3 59.4 59.5 59.6 59.7 59.8 59.9 60.0 60.1 60.2 60.3 60.4 60.5 60.6 60.7 60.8 60.9 61.0 61.1 61.2 61.3 61.4 61.5 61.6 61.7 61.8 61.9 62.0 62.1 62.2 62.3 62.4 62.5 62.6 62.7 62.8 62.9 63.0 63.1 63.2 63.3 63.4 63.5 63.6 63.7 63.8 63.9 64.0 64.1 64.2 64.3 64.4 64.5 64.6 64.7 64.8 64.9 65.0 65.1 65.2 65.3 65.4 65.5 65.6 65.7 65.8 65.9 66.0 66.1 66.2 66.3 66.4 66.5 66.6 66.7 66.8 66.9 67.0 67.1 67.2 67.3 67.4 67.5 67.6 67.7 67.8 67.9 68.0 68.1 68.2 68.3 68.4 68.5 68.6 68.7 68.8 68.9 69.0 69.1 69.2 69.3 69.4 69.5 69.6 69.7 69.8 69.9 70.0 70.1 70.2 70.3 70.4 70.5 70.6 70.7 70.8 70.9 71.0 71.1 71.2 71.3 71.4 71.5 71.6 71.7 71.8 71.9 72.0 72.1 72.2 72.3 72.4 72.5 72.6 72.7 72.8 72.9 73.0 73.1 73.2 73.3 73.4 73.5 73.6 73.7 73.8 73.9 74.0 74.1 74.2 74.3 74.4 74.5 74.6 74.7 74.8 74.9 75.0 75.1 75.2 75.3 75.4 75.5 75.6 75.7 75.8 75.9 76.0 76.1 76.2 76.3 76.4 76.5 76.6 76.7 76.8 76.9 77.0 77.1 77.2 77.3 77.4 77.5 77.6 77.7 77.8 77.9 78.0 78.1 78.2 78.3 78.4 78.5 78.6 78.7 78.8 78.9 79.0 79.1 79.2 79.3 79.4 79.5 79.6 79.7 79.8 79.9 80.0 80.1 80.2 80.3 80.4 80.5 80.6 80.7 80.8 80.9 81.0 81.1 81.2 81.3 81.4 81.5 81.6 81.7 81.8 81.9 82.0 82.1 82.2 82.3 82.4 82.5 82.6 82.7 82.8 82.9 83.0 83.1 83.2 83.3 83.4 83.5 83.6 83.7 83.8 83.9 84.0 84.1 84.2 84.3 84.4 84.5 84.6 84.7 84.8 84.9 85.0 85.1 85.2 85.3 85.4 85.5 85.6 85.7 85.8 85.9 86.0 86.1 86.2 86.3 86.4 86.5 86.6 86.7 86.8 86.9 87.0 87.1 87.2 87.3 87.4 87.5 87.6 87.7 87.8 87.9 88.0 88.1 88.2 88.3 88.4 88.5 88.6 88.7 88.8 88.9 89.0 89.1 89.2 89.3 89.4 89.5 89.6 89.7 89.8 89.9 90.0 90.1 90.2 90.3 90.4 90.5 90.6 90.7 90.8 90.9 91.0 91.1 91.2 91.3 91.4 91.5 91.6 91.7 91.8 91.9 92.0 92.1 92.2 92.3 92.4 92.5 92.6 92.7 92.8 92.9 93.0 93.1 93.2 93.3 93.4 93.5 93.6 93.7 93.8 93.9 94.0 94.1 94.2 94.3 94.4 94.5 94.6 94.7 94.8 94.9 95.0 95.1 95.2 95.3 95.4 95.5 95.6 95.7 95.8 95.9 96.0 96.1 96.2 96.3 96.4 96.5 96.6 96.7 96.8 96.9 97.0 97.1 97.2 97.3 97.4 97.5 97.6 97.7 97.8 97.9 98.0 98.1 98.2 98.3 98.4 98.5 98.6 98.7 98.8 98.9 99.0 99.1 99.2 99.3 99.4 99.5 99.6 99.7 99.8 99.9 100.0 100.1 100.2 100.3 100.4 100.5 100.6 100.7 100.8 100.9 101.0 101.1 101.2 101.3 101.4 101.5 101.6 101.7 101.8 101.9 102.0 102.1 102.2 102.3 102.4 102.5 102.6 102.7 102.8 102.9 103.0 103.1 103.2 103.3 103.4 103.5 103.6 103.7 103.8 103.9 104.0 104.1 104.2 104.3 104.4 104.5 104.6 104.7 104.8 104.9 105.0 105.1 105.2 105.3 105.4 105.5 105.6 105.7 105.8 105.9 106.0 106.1 106.2 106.3 106.4 106.5 106.6 106.7 106.8 106.9 107.0 107.1 107.2 107.3 107.4 107.5 107.6 107.7 107.8 107.9 108.0 108.1 108.2 108.3 108.4 108.5 108.6 108.7 108.8 108.9 109.0 109.1 109.2 109.3 109.4 109.5 109.6 109.7 109.8 109.9 110.0 110.1 110.2 110.3 110.4 110.5 110.6 110.7 110.8 110.9 111.0 111.1 111.2 111.3 111.4 111.5 111.6 111.7 111.8 111.9 112.0 112.1 112.2 112.3 112.4 112.5 112.6 112.7 112.8 112.9 113.0 113.1 113.2 113.3 113.4 113.5 113.6 113.7 113.8 113.9 114.0 114.1 114.2 114.3 114.4 114.5 114.6 114.7 114.8 114.9 115.0 115.1 115.2 115.3 115.4 115.5 115.6 115.7 115.8 115.9 116.0 116.1 116.2 116.3 116.4 116.5 116.6 116.7 116.8 116.9 117.0 117.1 117.2 117.3 117.4 117.5 117.6 117.7 117.8 117.9 118.0 118.1 118.2 118.3 118.4 118.5 118.6 118.7 118.8 118.9 119.0 119.1 119.2 119.3 119.4 119.5 119.6 119.7 119.8 119.9 120.0 120.1 120.2 120.3 120.4 120.5 120.6 120.7 120.8 120.9 121.0 121.1 121.2 121.3 121.4 121.5 121.6 121.7 121.8 121.9 122.0 122.1 122.2 122.3 122.4 122.5 122.6 122.7 122.8 122.9 123.0 123.1 123.2 123.3 123.4 123.5 123.6 123.7 123.8 123.9 124.0 124.1 124.2 124.3 124.4 124.5 124.6 124.7 124.8 124.9 125.0 125.1 125.2 125.3 125.4 125.5 125.6 125.7 125.8 125.9 126.0 126.1 126.2 126.3 126.4 126.5 126.6 126.7 126.8 126.9 127.0 127.1 127.2 127.3 127.4 127.5 127.6 127.7 127.8 127.9 128.0 128.1 128.2 128.3 128.4 128.5 128.6 128.7 128.8 128.9 129.0 129.1 129.2 129.3 129.4 129.5 129.6 129.7 129.8 129.9 130.0 130.1 130.2 130.3 130.4 130.5 130.6 130.7 130.8 130.9 131.0 131.1 131.2 131.3 131.4 131.5 131.6 131.7 131.8 131.9 132.0 132.1 132.2 132.3 132.4 132.5 132.6 132.7 132.8 132.9 133.0 133.1 133.2 133.3 133.4 133.5 133.6 133.7 133.8 133.9 134.0 134.1 134.2 134.3 134.4 134.5 134.6 134.7 134.8 134.9 135.0 135.1 135.2 135.3 135.4 135.5 135.6 135.7 135.8 135.9 136.0 136.1 136.2 136.3 136.4 136.5 136.6 136.7 136.8 136.9 137.0 137.1 137.2 137.3 137.4 137.5 137.6 137.7 137.8 137.9 138.0 138.1 138.2 138.3 138.4 138.5 138.6 138.7 138.8 138.9 139.0 139.1 139.2 139.3 139.4 139.5 139.6 139.7 139.8 139.9 140.0 140.1 140.2 140.3 140.4 140.5 140.6 140.7 140.8 140.9 141.0 141.1 141.2 141.3 141.4 141.5 141.6 141.7 141.8 141.9 142.0 142.1 142.2 142.3 142.4 142.5 142.6 142.7 142.8 142.9 143.0 143.1 143.2 143.3 143.4 143.5 143.6 143.7 143.8 143.9 144.0 144.1 144.2 144.3 144.4 144.5 144.6 144.7 144.8 144.9 145.0 145.1 145.2 145.3 145.4 145.5 145.6 145.7 145.8 145.9 146.0 146.1 146.2 146.3 146.4 146.5 146.6 146.7 146.8 146.9 147.0 147.1 147.2 147.3 147.4 147.5 147.6 147.7 147.8 147.9 148.0 148.1 148.2 148.3 148.4 148.5 148.6 148.7 148.8 148.9 149.0 149.1 149.2 149.3 149.4 149.5 149.6 149.7 149.8 149.9 150.0 150.1 150.2 150.3 150.4 150.5 150.6 150.7 150.8 150.9 151.0 151.1 151.2 151.3 151.4 151.5 151.6 151.7 151.8 151.9 152.0 152.1 152.2 152.3 152.4 152.5 152.6 152.7 152.8 152.9 153.0 153.1 153.2 153.3 153.4 153.5 153.6 153.7 153.8 153.9 154.0 154.1 154.2 154.3 154.4 154.5 154.6 154.7 154.8 154.9 155.0 155.1 155.2 155.3 155.4 155.5 155.6 155.7 155.8 155.9 156.0 156.1 156.2 156.3 156.4 156.5 156.6 156.7 156.8 156.9 157.0 157.1 157.2 157.3 157.4 157.5 157.6 157.7 157.8 157.9 158.0 158.1 158.2 158.3 158.4 158.5 158.6 158.7 158.8 158.9 159.0 159.1 159.2 159.3 159.4 159.5 159.6 159.7 159.8 159.9 160.0 160.1 160.2 160.3 160.4 160.5 160.6 160.7 160.8 160.9 161.0 161.1 161.2 161.3 161.4 161.5 161.6 161.7 161.8 161.9 162.0 162.1 162.2 162.3 162.4 162.5 162.6 162.7 162.8 162.9 163.0 163.1 163.2 163.3 163.4 163.5 163.6 163.7 163.8 163.9 164.0 164.1 164.2 164.3 164.4 164.5 164.6 164.7 164.8 164.9 165.0 165.1 165.2 165.3 165.4 165.5 165.6 165.7 165.8 165.9 166.0 166.1 166.2 166.3 166.4 166.5 166.6 166.7 166.8 166.9 167.0 167.1 167.2 167.3 167.4 167.5 167.6 167.7 167.8 167.9 168.0 168.1 168.2 168.3 168.4 168.5 168.6 168.7 168.8 168.9 169.0 169.1 169.2 169.3 169.4 169.5 169.6 169.7 169.8 169.9 170.0 170.1 170.2 170.3 170.4 170.5 170.6 170.7 170.8 170.9 171.0 171.1 171.2 171.3 171.4 171.5 171.6 171.7 171.8 171.9 172.0 172.1 172.2 172.3 172.4 172.5 172.6 172.7 172.8 172.9 173.0 173.1 173.2 173.3 173.4 173.5 173.6 173.7 173.8 173.9 174.0 174.1 174.2 174.3 174.4 174.5 174.6 174.7 174.8 174.9 175.0 175.1 175.2 175.3 175.4 175.5 175.6 175.7 175.8 175.9 176.0 176.1 176.2 176.3 176.4 176.5 176.6 176.7 176.8 176.9 177.0 177.1 177.2 177.3 177.4 177.5 177.6 177.7 177.8 177.9 178.0 178.1 178.2 178.3 178.4 178.5 178.6 178.7 178.8 178.9 179.0 179.1 179.2 179.3 179.4 179.5 179.6 179.7 179.8 179.9 180.0 180.1 180.2 180.3 180.4 180.5 180.6 180.7 180.8 180.9 181.0 181.1 181.2 181.3 181.4 181.5 181.6 181.7 181.8 181.9 182.0 182.1 182.2 182.3 182.4 182.5 182.6 182.7 182.8 182.9 183.0 183.1 183.2 183.3 183.4 183.5 183.6 183.7 183.8 183.9 184.0 184.1 184.2 184.3 184.4 184.5 184.6 184.7 184.8 184.9 185.0 185.1 185.2 185.3 185.4 185.5 185.6 185.7 185.8 185.9 186.0 186.1 186.2 186.3 186.4 186.5 186.6 186.7 186.8 186.9 187.0 187.1 187.2 187.3 187.4 187.5 187.6 187.7 187.8 187.9 188.0 188.1 188.2 188.3 188.4 188.5 188.6 188.7 188.8 188.9 189.0 189.1 189.2 189.3 189.4 189.5 189.6 189.7 189.8 189.9 190.0 190.1 190.2 190.3 190.4 190.5 190.6 190.7 190.8 190.9 191.0 191.1 191.2 191.3 191.4 191.5 191.6 191.7 191.8 191.9 192.0 192.1 192.2 192.3 192.4 192.5 192.6 192.7 192.8 192.9 193.0 193.1 193.2 193.3 193.4 193.5 193.6 193.7 193.8 193.9 194.0 194.1 194.2 194.3 194.4 194.5 194.6 194.7 194.8 194.9 195.0 195.1 195.2 195.3 195.4 195.5 195.6 195.7 195.8 195.9 196.0 196.1 196.2 196.3 196.4 196.5 196.6 196.7 196.8 196.9 197.0 197.1 197.2 197.3 197.4 197.5 197.6 197.7 197.8 197.9 198.0 198.1 198.2 198.3 198.4 198.5 198.6 198.7 198.8 198.9 199.0 199.1 199.2 199.3 199.4 199.5 199.6 199.7 199.8 199.9 200.0 200.1 200.2 200.3 200.4 200.5 200.6 200.7 200.8 200.9 201.0 201.1 201.2 201.3 201.4 201.5 201.6 201.7 201.8 201.9 202.0 202.1 202.2 202.3 202.4 202.5 202.6 202.7 202.8 202.9 203.0 203.1 203.2 203.3 203.4 203.5 203.6 203.7 203.8 203.9 204.0 204.1 204.2 204.3 204.4 204.5 204.6 204.7 204.8 204.9 205.0 205.1 205.2 205.3 205.4 205.5 205.6 205.7 205.8 205.9 206.0 206.1 206.2 206.3 206.4 206.5 206.6 206.7 206.8 206.9 207.0 207.1 207.2 207.3 207.4 207.5 207.6 207.7 207.8 207.9 208.0 208.1 208.2 208.3 208.4 208.5 208.6 208.7 208.8 208.9 209.0 209.1 209.2 209.3 209.4 209.5 209.6 209.7 209.8 209.9 210.0 210.1 210.2 210.3 210.4 210.5 210.6 210.7 210.8 210.9 211.0 211.1 211.2 211.3 211.4 211.5 211.6 211.7 211.8 211.9 212.0 212.1 212.2 212.3 212.4 212.5 212.6 212.7 212.8 212.9 213.0 213.1 213.2 213.3 213.4 213.5 213.6 213.7 213.8 213.9 214.0 214.1 214.2 214.3 214.4 214.5 214.6 214.7 214.8 214



Thanks a lot Florent Morselli



@Spomky

[Security] Access Token Authenticator #46428

Merged by chalasr symfony:6.2 ← Spomky:features/access-token-authenticator on Aug 10

Conversation 195 Commits 1 Checks 7 Files changed 39 +1,994 -1

Spomky (Florent Morselli) on May 21 • edited

Q	A
Branch?	6.2
Bug fix?	yes
New feature?	yes
Deprecations?	no
Tickets	Fix #45844
License	MIT
Doc PR	symfony/symfony-docs#16819

Hi,

This PR aims at fixing [#45844](#).
It adds a new authenticator that is able to fetch a token in the request header and retrieve the associated user identifier.

The authenticator delegates the token loading to a handler. This handler could manage opaque tokens (random strings stored in a database) or self-contained tokens such as JWT, Paseto, SAML...

Reviewers – review now

vincentchalamon

lyrixx

stolt

94noni

derrabus

dunglas

wouterj

chalasr

Assignees – assign yourself

Labels

Bug x

Feature x

Ready x

Security x

Status: Reviewed x

Projects

None yet



SymfonyCon
DISNEYLAND PARIS
NOV.17-18 2022

**Adding a feature to
Symfony could take years**



Let's meet **AccessTokenAuthenticator** in *Symfony 6.2*

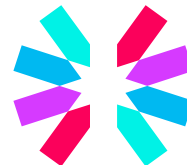
AccessTokenAuthenticator

- Takes care of token extraction
 - Header
 - Query string
 - Request body
 - And/or your **Custom** extractors
- Calls **your Token Handler** to check the token (revocation, expiration, signature, ...)
- Custom success / failure handlers if needed

✨ All this via configuration!

What kind of tokens could be used?

- JWT
- SAML2
- Biscuit
- Macaroons
- Homemade tokens (with chocolate chips and nuts 🍪)
- ...
- Any kind of token, as it's up to you to handle them



⚙ Internally, in Symfony

- Extraction with `ChainTokenExtractor` (configurable order)
 - Default and custom extractors can be used at the same time
- Handle the token with **your** `TokenHandlerInterface` implementation
- `AccessTokenAuthenticator` will
 - create a `PostAuthenticationToken` object
 - set `WWW-Authenticate` Response header content in case of failure
 - use the configured User Provider in `security.yaml`

🪄 How much easier is it
with 6.2?

6.1 security.yaml

```
1  security:
2    providers:
3      user_provider:
4        entity:
5          class: App\Entity\User
6          property: apiKey
7    firewalls:
8      api:
9        pattern: ^/api
10       lazy: true
11       provider: user_provider
12       custom_authenticator: App\Security\ApiKeyAuthenticator
```

6.1 ApiKeyAuthenticator

```
1 class ApiKeyAuthenticator extends AbstractAuthenticator
2 {
3     public function __construct(
4         private readonly UserRepository $userRepository,
5         private readonly string $env,
6     ) {}
7
8     public function supports(Request $req): ?bool
9     {
10         return $req->headers->has('Authorization') || $req->query->has('access_token') || $req->request->has('access_token');
11     }
12
13     public function authenticate(Request $req): Passport
14     {
15         if (null === $apiKey = $this->extractToken($req)) {
16             throw new AuthenticationException('No API Key provided');
17         }
18
19         // Here, it could be some logic to validate the token
20
21         return new SelfValidatingPassport(
22             new UserBadge($apiKey,
23                 function (string $apiKey) {
24                     return $this->userRepository->findOneByApiKey($apiKey);
25                 }
26             )
27         );
28     }
29 }
```

6.1 ApiKeyAuthenticator

```
1 class ApiKeyAuthenticator extends AbstractAuthenticator
2 {
3     public function __construct(
4         private readonly UserRepository $userRepository,
5         private readonly string $env,
6     ) {}
7
8     public function supports(Request $req): ?bool
9     {
10         return $req->headers->has('Authorization') || $req->query->has('access_token') || $req->request->has('access_token');
11     }
12
13     public function authenticate(Request $req): Passport
14     {
15         if (null === $apiKey = $this->extractToken($req)) {
16             throw new AuthenticationException('No API Key provided');
17         }
18
19         // Here, it could be some logic to validate the token
20
21         return new SelfValidatingPassport(
22             new UserBadge($apiKey,
23                 function (string $apiKey) {
24                     return $this->userRepository->findOneByApiKey($apiKey);
25                 }
26             )
27         );
28     }
29 }
```

6.1 ApiKeyAuthenticator

```
1 class ApiKeyAuthenticator extends AbstractAuthenticator
2 {
3     public function __construct(
4         private readonly UserRepository $userRepository,
5         private readonly string $env,
6     ) {}
7
8     public function supports(Request $req): ?bool
9     {
10         return $req->headers->has('Authorization') || $req->query->has('access_token') || $req->request->has('access_token');
11     }
12
13     public function authenticate(Request $req): Passport
14     {
15         if (null === $apiKey = $this->extractToken($req)) {
16             throw new AuthenticationException('No API Key provided');
17         }
18
19         // Here, it could be some logic to validate the token
20
21         return new SelfValidatingPassport(
22             new UserBadge($apiKey,
23                 function (string $apiKey) {
24                     return $this->userRepository->findOneByApiKey($apiKey);
25                 }
26             )
27         );
28     }
29 }
```

6.1 ApiKeyAuthenticator

```
1  /** Simplified version */
2  private function extractToken(Request $req): ?string
3  {
4      return match (true) {
5          // Header
6          $req->headers->has('Authorization') => str_replace('Bearer ', '', $req->headers->get('Authorization')),
7
8          // Query string
9          $req->query->has('access_token') => $req->query->get('access_token'),
10
11         // Request body
12         $req->request->has('access_token') => $req->request->get('access_token'),
13
14         default => null,
15     };
16 }
```

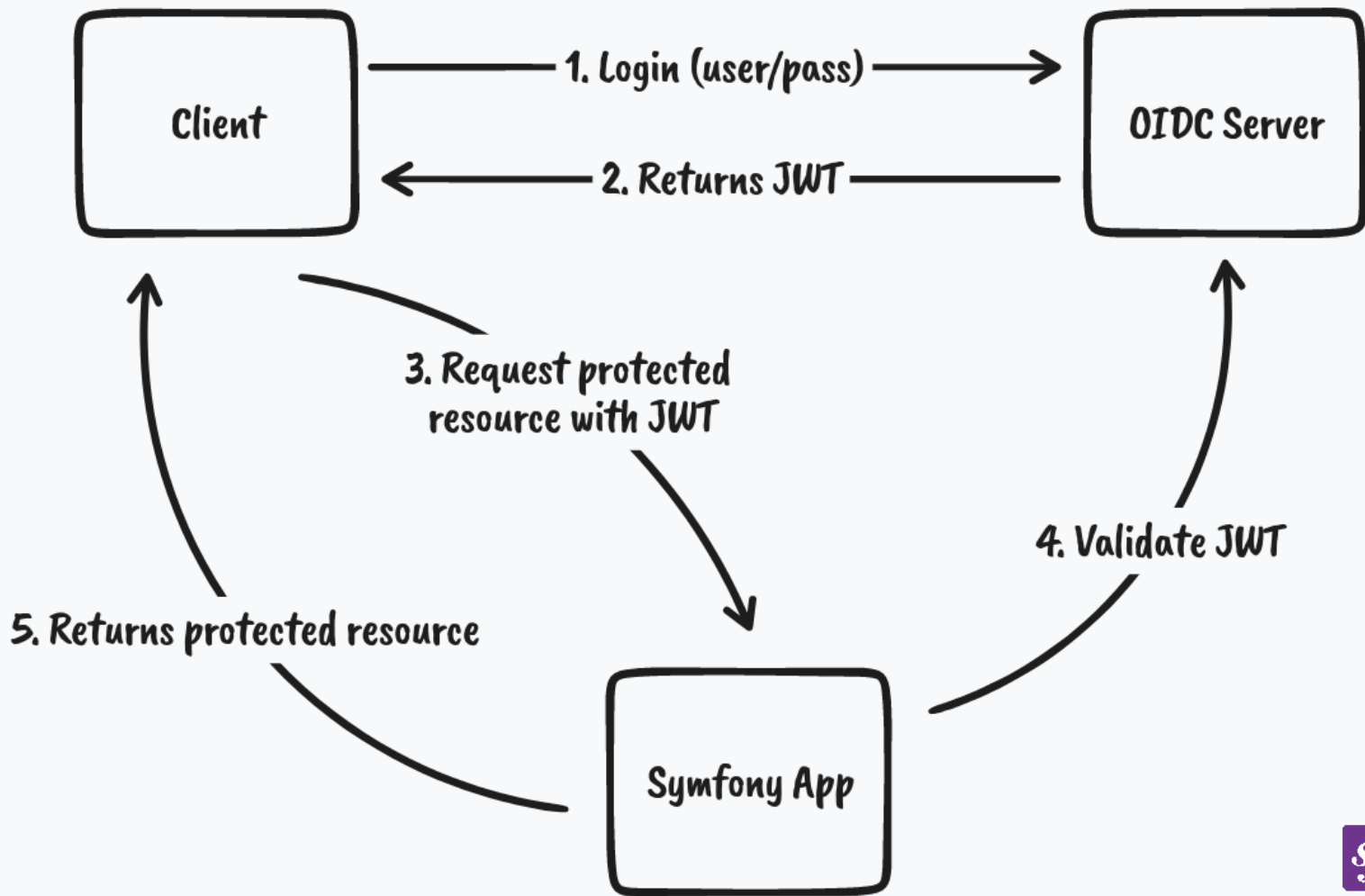
6.2 security.yaml

```
1  security:
2    providers:
3      user_provider:
4        entity:
5          class: App\Entity\User
6          property: apiKey
7    firewalls:
8      api:
9        pattern: ^/api
10       lazy: true
11       provider: user_provider
12       access_token:
13         token_extractors:
14           - header
15           - query_string
16           - request_body
17       token_handler: App\Security\AccessTokenHandler
```

6.2 AccessTokenHandler

```
1 class AccessTokenHandler implements AccessTokenHandlerInterface
2 {
3     public function __construct(
4         private readonly UserRepository $userRepository,
5         private readonly string $env,
6     ) {}
7
8     public function getUserIdentifierFrom(string $token): string
9     {
10         $user = $this->userRepository->findOneByApiKey($token);
11
12         if ($user === null) {
13             throw new BadCredentialsException('Invalid credentials.');
```

6.2 With a JWT issued by an OIDC server





6.2 With a JWT issued by an OIDC server

```
1 class JwtHandler implements AccessTokenHandlerInterface
2 {
3     public function __construct(
4         private readonly HttpClientInterface $oidcHttpClient,
5     ) {}
6
7     public function getUserIdentifierFrom(string $accessToken): string
8     {
9         try {
10             $userInfo = $this->oidcHttpClient->request('GET', 'protocol/openid-connect/userinfo', [
11                 'auth_bearer' => $accessToken,
12             ]->toArray());
13         } catch (HttpExceptionInterface $e) {
14             throw new BadCredentialsException($e->getMessage());
15         }
16
17         return $userInfo['email'];
18     }
19 }
```

6.2 With a JWT issued by your *Symfony* app

with lcobucci/jwt

(or web-token/jwt-checker)



6.2 security.yaml

```
1 security:
2   providers:
3     user_provider:
4       entity:
5         class: App\Entity\User
6         property: email
7   firewalls:
8     api:
9       pattern: ^/api
10      lazy: true
11      provider: user_provider
12      access_token:
13        token_extractors: header
14        token_handler: App\Security\JwtHandler
```

6.2 JwtHandler

```
1  class JwtHandler implements AccessTokenHandlerInterface
2  {
3      public function __construct(
4          private readonly Parser $jwtParser = new Parser(new JoseEncoder()),
5          private readonly Validator $jwtValidator = new Validator(),
6      ) {}
7
8      public function getUserIdentifierFrom(string $accessToken): string
9      {
10         $jwt = $this->jwtParser->parse($accessToken);
11         $timezone = new \DateTimeZone('Europe/Paris');
12
13         try {
14             $this->jwtValidator->assert($jwt, new ValidAt(new SystemClock($timezone)));
15             $this->jwtValidator->assert($jwt, new SignedWith(
16                 new Sha256(),
17                 InMemory::plainText('PRIVATE-KEY')
18             ));
19         } catch (RequiredConstraintsViolated $e) {
20             throw new BadCredentialsException($e->getMessage());
21         }
22
23         return $jwt->claims()->get(RegisteredClaims::SUBJECT);
24     }
25 }
```

API Platform plans to support OpenID Connect authentication



<https://github.com/api-platform/demo/pull/265>

api-platform / demo Public

Code Issues 1 Pull requests 1 Actions

Add Keycloak authentication #265

Draft main test/keycloak

Conversation 32 Commits 2 Checks 0 Files changed 57 +1,331 -985

vincentchalamon (Vincent) on Apr 13 • edited

- ☒ Use AccessTokenAuthenticator
- ☒ Validate JWT on Keycloak (requires Keycloak to run separately)
- ☒ Add functional tests
- ☒ Configure Keycloak Helm Chart ([keycloak-pr-265-demo.api-platform.com](#))
- ☒ Configure Keycloak demo realm on Helm Chart
- ☐ Fix admin authentication (waiting for [marmelab/ra-keycloak](#))
- ☐ Update dependencies (waiting for Symfony 6.2 stable in november)

Contributor

Reviewers — review now

- dunglas
- chalar
- jfcoz
- GregoireHebert

Assignees

- vincentchalamon



In the future?

- Add a native JwtHandler to Symfony?
- Add a native SamlHandler to Symfony?
- Add a native BiscuitHandler to Symfony?



It's up to the community!

Your responsibility

Symfony's responsibility,
but customizable

Access Token Authentication Process

<= 6.1



6.2

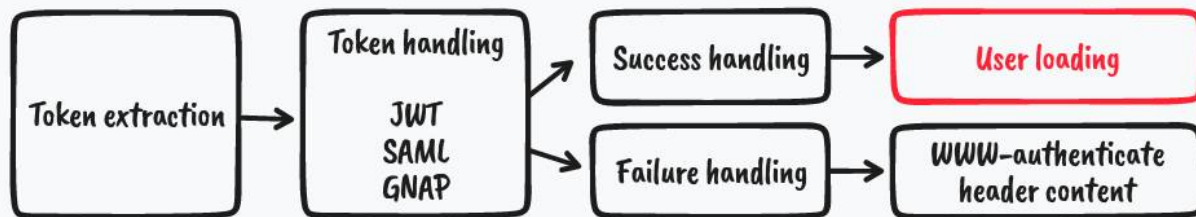


Your responsibility

Symfony's responsibility,
but customizable

Access Token Authentication Process

6.3 ?



Less responsibility, less code

- **Configure** the way the extraction should be done
- **Focus** on the token processing
 - Decoding
 - Checking signature, expiration, revocation
 - Retrieve user identifier



Leverage all Symfony power to fine tune configuration to your needs

 **Thanks a lot**

Wouter
Guillaume
Vincent
Florent

And all reviewers, commenters 

Thank you



Any questions?

Slides and demo apps 🖱️ welcomattic.github.io/painless-authentication-with-access-token

Sources

- [JWT RFC](#)
- [Bearer Token Usage RFC](#)
- [In-depth article about token authentication](#)